

GROUP ASSIGNMENT · CLO3 · 20%**Cloud SLA & Data-Privacy Compliance Assessment**

Assessment Brief — group compliance report, technical evidence pack and board briefing note

Course Details

Item	Detail
Institute	Malaysian Institute of Information Technology (UniKL MIIT)
Course name	Cloud Computing Security Essentials
Course code	IKB42603
Course leader / Lecturer	Prof. Dr. Shahrulniza Musa/Ts. Noor Hazlina Abdul Mutalib/ Ts. Nor Adani Kamal Mohamad Nasir
Semester & Year	Short Sem July 2026

Assessment Details

Item	Detail
Title / name	Assignment — Cloud SLA & Data-Privacy Compliance Assessment
Assessment type	Group assignment (written report, technical evidence pack and board briefing note)
Group size	3–4 students per group
Weighting	20% of the course
Released / Deadline	Released: 24 August 2026 Due: 11 September 2026
Course Learning Outcome	CLO3 — Present the compliance of cloud computing services with their Service Level Agreements and data-privacy obligations with professional integrity. (A2, PLO9, MQF iii(f))
Values & sustainability	VBE3 — Integrity (professional, honest reporting) · supports SDG 9.1 (resilient, inclusive infrastructure)

1. Purpose & Alignment

This assignment assesses CLO3: your ability to evaluate whether a cloud service — through its Service Level Agreement (SLA) and data-handling practices — meets an organisation's compliance and data-privacy obligations, and to **present/report that to management**.

You will act as a cloud security & compliance consultancy engaged by a client. Your professional obligation is to report findings honestly and with evidence — including where the service falls short — which is the VBE3 integrity value at the heart of this outcome.

Note: The 'present to management' requirement of CLO3 is met by the **board briefing note** described in Section 7 — a short, self-contained written brief addressed to MediPay's board, submitted alongside the report and marked as its own rubric criterion.

2. The Scenario

MediPay Sdn Bhd is a Malaysian fintech-health start-up. It runs a multi-tenant SaaS platform that serves clinics across Malaysia and handles two categories of sensitive data:

- **Payment-card data** for clinic billing — subject to PCI DSS.
- **Personal health information (PHI)** of patients — subject to the Personal Data Protection Act (PDPA) 2010, as amended by the Personal Data Protection (Amendment) Act 2024, and health-privacy expectations (ISO/IEC 27018 for cloud Personally Identifiable Information (PII)). The 2024 amendments, in force from 1 June 2025, introduce mandatory data breach notification — to the Commissioner as soon as practicable and no later than 72 hours, and to affected data subjects within 7 days of that — mandatory appointment and registration of a Data Protection Officer, direct obligations on data processors, a right to data portability, and a reformed cross-border transfer test in place of the former whitelist. Wherever this brief refers to the PDPA, it means the Act as amended.

MediPay plans to migrate this platform to a public cloud provider and has shortlisted one provider's offering, including its standard SLA and a CSA STAR self-assessment. MediPay's board is concerned about data residency, breach notification and whether the provider's shared-responsibility split leaves compliance gaps. Your group has been engaged to assess the proposed service against MediPay's compliance and data-privacy obligations and to report your findings and recommendation to the board.

Note: You may use the MediPay scenario as given, or propose an equivalent regulated multi-tenant scenario (e.g. e-government, banking, e-commerce with card + personal data)

3. Your Task

1. **Define the scope & obligations.** Identify the data types, the applicable standards and laws (PCI DSS, ISO/IEC 27017 & 27018, the PDPA as amended in 2024, and the CSA Cloud Controls Matrix), and what each requires.
2. **Assess the provider.** Using the shared-responsibility model and the provider's CSA STAR / CAIQ evidence, determine which controls the provider covers versus which remain MediPay's responsibility.
3. **Analyse the SLA.** Evaluate the SLA against MediPay's needs — availability, security & breach-notification terms, data location / residency, audit rights, and data return / deletion on exit — and identify gaps.
4. **Assess data-privacy & integrity safeguards.** For the key obligations, build a requirement → control → evidence mapping showing how (or whether) confidentiality, integrity and privacy of tenant data are preserved.
5. **Produce a technical evidence pack.** Collect reproducible technical evidence from your own lab environment, mapped to CSA CCM control IDs — see Section 6.

6. **Identify gaps & recommend remediation.** State clearly where the service does NOT meet obligations, with an owned, prioritised remediation plan.
7. **Conclude with a recommendation to the board** (adopt / adopt-with-conditions / reject) — justified and evidence-based.
8. **Write the board briefing note** (Section 7), presenting your case to management with professional integrity.

4. Deliverables

Four components:

#	Deliverable	Detail
1	Group compliance report	2,500–3,500 words — structure in Section 5
2	Technical evidence pack	Appendix B and C of the report — requirements in Section 6
3	Board briefing note	1–2 pages, addressed to the board — requirements in Section 7
4	Group declaration & peer-contribution form	Signed; the Appendix to this brief

5. Report Structure & Format

Submit a professional compliance report with the following structure:

#	Section	What it must contain
1	Cover & group declaration	Title, group members & IDs, signed originality declaration.
2	Executive summary	The recommendation and key findings in half a page for the board.
3	Scope & obligations	Data types; applicable standards/laws (PCI DSS, ISO 27017/27018, the PDPA as amended, CCM) and what they require.
4	Provider & shared-responsibility assessment	What the provider covers vs MediPay, using STAR/CAIQ evidence.
5	SLA analysis	Availability, security, breach notice, residency, audit rights, exit/deletion — with a gap table.
6	Data-privacy & integrity assessment	Requirement → control → evidence mapping, including your technical evidence register (Section 6).
7	Gaps & remediation plan	Honest list of gaps with owners, priority and timeline.
8	Conclusion & recommendation	Adopt / adopt-with-conditions / reject — justified.
9	References & appendices	APA references; Appendix A supporting evidence; Appendix B evidence pack; Appendix C collection script.

- **Length:** 2,500–3,500 words (excluding cover, references and appendices) – 8-12 pages
- **Format:** A4, 11–12 pt professional font, headings, page numbers; tables/figures numbered.
- **Referencing:** APA 7th; cite standards and the provider's documents.
- **Submission:** one PDF per group via the course submission system (Turnitin-enabled) in VLE.

6. Technical Evidence Pack

Your report assesses MediPay's provider using the SLA, the CSA STAR entry and the CAIQ. All three are **documentary** evidence — they are the provider's assertions about itself. An assessment that stops there can only report what it was told.

An auditor asks a harder question: *show me the control operating*. This section requires you to produce that second kind of evidence from a system you actually control — the LocalStack environment you built — and to map each artefact to a Cloud Controls Matrix control ID, exactly as you would in a real engagement.

Security tip: This is the distinction between the two halves of your recommendation. Documentary evidence supports *the provider claims data at rest is encrypted*. Technical evidence supports *we verified the control is configured and enforced, by this command, producing this output*. Only the second survives a challenge.

6.1 What you must produce

A single evidence pack containing **at least eight** controls, each with all five columns completed. At minimum, cover the six control areas below; add two or more of your own that are material to MediPay's PCI DSS and PDPA obligations.

#	Control area	CCM domain (v4)	Where the command comes from
1	Identity & least privilege	IAM — Identity & Access Management	Lab 1
2	Tenant isolation & segmentation	IVS — Infrastructure & Virtualisation Security	Lab 2 · Lab 2 Zero Trust addendum
3	Encryption at rest & key management	CEK — Cryptography, Encryption & Key Management	Lab 3 · Lab 6 Task 5
4	Data classification & disposal	DSP — Data Security & Privacy Lifecycle	Lab 6 Tasks 1, 7, 8
5	Logging & management plane audit	LOG — Logging & Monitoring	Lab 5 · Lab 5 addendum A1
6	Secure development & pipeline gate	AIS — Application & Interface Security	Your own — see the collection script in 6.4

6.2 Required format

Every row of your evidence register must carry these five columns. A row missing the last two is a claim not evidence.

Column	What it must contain
Obligation	The specific requirement, cited — e.g. <i>PCI DSS 3.5.1</i> , <i>PDPA Security Principle</i> , <i>ISO/IEC 27018:2019 Annex A (Information security)</i>
CCM control ID	The Cloud Controls Matrix v4 control this maps to — e.g. CEK-03, DSP-04, LOG-07
Responsibility	Provider, customer, or shared — justified against the shared responsibility model for the service type
Verification method	The exact command or procedure, reproducible by a third party
Evidence & date	The output, labelled, with the date collected and who collected it

6.3 Worked example

Column	Example entry
Obligation	PCI DSS v4.0 Req. 3.5.1 — PAN must be rendered unreadable wherever it is stored
CCM control ID	CEK-03 (Data Encryption) · supported by CEK-08 (CSC Key Management Capability)
Responsibility	Shared — provider supplies the KMS and storage-layer encryption; customer must enable it, select a customer-managed key and enforce it on upload
Verification method	<code>aws \$EP s3api get-bucket-encryption --bucket \$BUCKET</code> and <code>aws \$EP s3api head-object --bucket \$BUCKET --key confidential/record.txt</code>
Evidence & date	Output showing <code>SSEAlgorithm: aws:kms</code> with a customer-managed <code>KMSMasterKeyID</code> , and <code>head-object</code> confirming an object uploaded with no encryption flags was still encrypted. Collected 12 Aug 2026 by [name].

Caution: Note what the example does **not** claim. It does not say 'card data is encrypted'. It says a specific configuration was observed on a specific date by a specific command. Overstating what your evidence supports is exactly the integrity failure that the professional integrity criterion penalises — and the one that ends careers in this profession.

6.4 Collecting the evidence

Assemble a single script that gathers your posture in one run. This is what a compliance engineer actually builds, and it is the difference between an assessment you can repeat and one you cannot.

```
#!/usr/bin/env bash
# MediPay compliance evidence collection - IKB42603
export EP='--endpoint-url=http://localhost:4566'
OUT="evidence-$(date +%Y%m%d).txt"

{
  echo "MediPay technical evidence pack"
  echo "Collected: $(date -u) by <your name>"

  echo "=== CEK-03 Encryption at rest ==="
```

```

aws $EP s3api get-bucket-encryption --bucket $BUCKET \
  --query 'ServerSideEncryptionConfiguration.Rules[0]' --output json

echo "=== DSP-04 Data classification ==="
aws $EP s3api get-object-tagging --bucket $BUCKET --key confidential/record.txt

echo "=== DSP-17 Public exposure guardrail ==="
aws $EP s3api get-public-access-block --bucket $BUCKET \
  --query 'PublicAccessBlockConfiguration' --output json

echo "=== DSP-16 Retention and disposal ==="
aws $EP s3api get-bucket-lifecycle-configuration --bucket $BUCKET \
  --query 'Rules[].[ID,Status]' --output json

echo "=== LOG-07 / LOG-02 Management plane audit trail ==="
# CloudTrail is not included in the course LocalStack licence.
# Reconstruct the management-plane trail from the request log
# instead (start the container with -e DEBUG=1). See Lab 5.1 A1.
docker logs "$LS_CONTAINER" 2>&1 \
  | grep -E "AWS [a-z0-9]+\.[A-Za-z]+ =>" > mgmt-trail.log
wc -l mgmt-trail.log
sha256sum mgmt-trail.log > mgmt-trail.sha256
aws $EP s3 cp mgmt-trail.sha256 s3://miit-audit-trail/

echo "=== IAM-05 Least privilege on execution roles ==="
aws $EP iam list-role-policies --role-name patient-lookup-role --output json

echo "=== AIS-06 Pipeline security gate ==="
bash ci-gate.sh > /dev/null 2>&1
echo "gate exit code: $? (0 = policy satisfied, 1 = blocked)"
} | tee "$OUT"

sha256sum "$OUT"
# macOS: use shasum -a 256 "$OUT"

```

Security tip: The final sha256sum is deliberate. Hashing your evidence file at collection time makes the pack tamper-evident — the same integrity mechanism you built in Lab 5 Task 4 and used again in the Lab 5.1 A1 sealed-digest trail. Quote the hash in your report and an assessor can confirm the appendix was not edited afterwards.

6.5 Where it goes

Report location	What to put there	Counts toward word limit?
Section 6 of the report	The evidence register table: eight or more rows, five columns each	Yes
Section 7 of the report	Every obligation you could not evidence, and why — this is a finding, not a failure	Yes
Appendix B	The raw evidence pack output and its SHA-256 hash	No

Appendix C	Your collection script	No
------------	------------------------	----

Note: Controls you cannot evidence are the most valuable part of this section. LocalStack cannot demonstrate physical security, provider personnel vetting, or multi-region failover — and neither can you, as a customer, for a real provider. Naming those honestly and stating what you would accept instead (an ISO 27001 certificate, a SOC 2 Type II report, a contractual audit right) is precisely the professional judgement CLO3 assesses.

7. Board Briefing Note

Write **one to two pages**, addressed to MediPay's board, as a self-contained document. A board member who reads only this note must be able to make the decision without opening the full report.

Element	What it must do
Audience & register	Written for non-technical directors. No unexplained acronyms; no command output; business consequence rather than technical mechanism.
The recommendation, first	Adopt, adopt-with-conditions, or reject — stated in the opening lines, not withheld until the end.
The three findings that matter most	Selected and prioritised by you. Say why these three and not others.
The honest picture	Lead with the gaps as well as the strengths. A briefing that reads as reassurance is not a professional briefing.
Consequence & exposure	What each gap means in regulatory and financial terms — including PDPA exposure and breach-notification duties.
What you are asking for	The specific decision, budget or acceptance of risk the board must give you.

Caution: The integrity test is here rather than in the report. It is always tempting to write a briefing that pleases the client. A board that adopts a non-compliant service because your note downplayed a gap has been failed by its consultants — and under VBE3 that is a professional failure, not a presentational one.

8. Group Arrangement & Peer Assessment

Work in groups of 3–4. Agree roles — for example standards and obligations, provider and SLA analysis, privacy and integrity, technical evidence collection, briefing-note lead — but every member must understand the whole assessment. **Each member submits a short peer-contribution rating for every group member.**

Note: Because this assessment no longer includes an individually delivered component, **the peer-contribution factor is now the sole mechanism for differentiating individual marks.** Complete it seriously. A peer factor may adjust an individual's mark where contribution is clearly unequal, and persistent non-contribution can result in an individually reduced mark at the lecturer's discretion.

9. Marking Scheme

The assignment is marked out of 100 using the single criterion-referenced rubric in Section 10, then scaled to the 20% course weighting. A peer-contribution factor (Appendix form) may adjust an individual's mark.

Component (within the rubric)	Weight	Basis
Report content & analysis	75%	Rubric criteria 1–5 — group mark
Board briefing note (A2 · PLO9)	10%	Rubric criterion 6 — group mark
Report structure & communication	5%	Rubric criterion 7 — group mark
Professional integrity (VBE3)	10%	Rubric criterion 8 — group mark
TOTAL	100%	Scaled to 20% of the course; peer factor adjusts individuals

Note: Report content & analysis (75%) comprises obligations & standards, provider & SLA analysis, data-privacy & integrity safeguards, the technical evidence pack, and gaps & remediation — 15% each is shown in the Section 10 rubric. The rubric is also provided as an Excel grading workbook (Assignment Rubric + Peer & Final sheets) aligned to CLO3.

10. Marking Rubric (CLO3-aligned)

Criterion-referenced; four achievement levels plus zero for not attempted; weighted to 100. Adapted from UniKL CDDH Appendix L and aligned to CLO3 (A2 · PLO9 · VBE3).

Field	Detail
Course code & name	IKB42603 — Cloud Computing Security Essentials
Assessment	Group Assignment — Cloud SLA & Data-Privacy Compliance Assessment
CLO / clusters	CLO3 · A2 (Affective — respond) · PLO9 (Ethics & Professionalism) · VBE3 (Integrity) · MQF iii(f)
Group / Members	
Assessment date	

Criteria (aligned to CLO3 · PLO9 · VBE3 · A2)	Unsatisfactory (1)	Marginal (2)	Acceptable (3)	Exceptional (4)	Weight
1. Understanding of obligations & standards	Little grasp of applicable standards/laws.	Some obligations identified; gaps in understanding.	Correct standards & obligations identified and explained.	Thorough, insightful mapping of PCI DSS, ISO 27017/18, PDPA, CCM to the scenario.	15%
2. Provider & SLA compliance analysis	No real analysis; description only.	Basic analysis; shared responsibility / SLA gaps missed.	Sound analysis of provider (STAR/CAIQ) and SLA with gaps identified.	Rigorous, evidence-based analysis; precise gap identification and impact.	15%

3. Data-privacy & integrity safeguards (VBE3)	Ignores data protection/privacy.	Partial; requirement→control mapping incomplete.	Sound requirement→control→evidence mapping; CIA & privacy addressed.	Comprehensive, well-justified safeguarding of integrity & privacy.	15%
4. Technical evidence pack	No technical evidence; documentary claims only.	Some commands shown; not mapped to CCM or undated.	Eight or more controls, five columns complete, CCM-mapped and dated.	Reproducible, hash-verified pack; unevidenced controls named with alternative assurance.	15%
5. Gaps, remediation & recommendation	No gaps or recommendation.	Some gaps; weak/unjustified recommendation.	Clear gaps with a prioritised remediation plan and justified recommendation.	Insightful, owned remediation plan; decisive, well-argued recommendation.	15%
6. Board briefing note (A2 · PLO9)	Missing, or unusable by a non-technical board.	Restates the report; recommendation buried or hedged.	Clear, self-contained brief; recommendation stated up front with consequences.	Persuasive and candid; leads with gaps, quantifies exposure, asks for a specific decision.	10%
7. Report structure & communication	Poorly organised; hard to follow.	Basic structure; some clarity issues.	Well-structured, clear, professionally presented with references.	Polished, coherent, audience-appropriate; excellent evidence & referencing.	5%
8. Professional integrity (VBE3)	Overstates compliance / hides gaps; unsupported claims.	Some honesty; evidence inconsistent.	Honest findings, evidence-based, gaps disclosed.	Exemplary integrity: candid, evidence-led, responsible advice to the client.	10%
TOTAL					100%

Scoring: circle the Level (0–4) per criterion. Level points = 0 Not attempted or nothing creditable presented, 1 Unsatisfactory, 2 Marginal, 3 Acceptable, 4 Exceptional. Criterion mark = $(\text{Level} \div 4) \times \text{Weight}$. Sum for the assignment mark out of 100, then scale to the 20% course weighting. A deliverable that is not submitted — for example the board briefing note or the technical evidence pack — scores 0 on its criterion, so the assignment mark can fall below 25. The peer-contribution factor may adjust individual marks.

11. Academic Integrity

- All work must be the group's own. Reports are checked via Turnitin; a high similarity index will be investigated.
- Generative-AI use must be declared and used only as permitted by the lecturer; AI-generated text presented as your own is misconduct.
- In keeping with VBE3 integrity, report findings honestly — fabricating evidence or overstating compliance is both academic misconduct and a professional failing.

- Your technical evidence must come from an environment you actually ran. Fabricated command output is fabricated evidence.

12. Submission

- **Report** (including Appendices B and C): one PDF per group via the course submission system by the end of Week 11.
- **Board briefing note:** submitted with the report, as a separate PDF or a clearly marked section of the same file.
- **Group declaration & peer-contribution form:** signed, submitted with the report.
- Late submission is penalised per UniKL policy unless an extension is approved in advance.

Appendix — Group Declaration & Peer-Contribution Form

We declare that this assignment is our own work and that all sources have been acknowledged. We confirm the contribution ratings below are a fair reflection of each member's effort.

#	Member name	Student ID	Role / contribution	Peer rating (1–5)	Signature
1					
2					
3					
4					

Peer rating scale: 5 = outstanding contribution · 4 = strong · 3 = adequate · 2 = limited · 1 = minimal / none.

Due date
B03 - 9/9